PHP の重大な脆弱性　確認の手順

INCERTO

CVE-2026-109618 / CVE-2026-109619（2026年10月21日 修正版公開）　2026年10月21日

1. 今回の脆弱性

中身	外部から、ログインなしでサーバー上の不正なプログラムを実行されるおそれ
対象	修正版より前のすべての版
修正版	**8.2.35 ／ 8.3.36 ／ 8.4.27 ／ 8.5.12**
8.1 以前	サポートが終わっていて、修正版は出ません。サポート中の版へ上げる必要があります
確実な対策	修正版への更新（開発元の告知）

出典：PHP の開発元の告知 https://github.com/php/php-src/security/advisories/GHSA-w8hw-w9fx-j79w ／ GHSA-6wmf-4rv5-p3rp

2. レンタルサーバー（共用）の上のサイト

PHP の本体はサーバー会社が更新します。ただし、使う版はサイトごとに選べることが多いため、**サイトごとに版を確かめます。**

確かめる場所	見るところ
WordPress の管理画面	「ツール → サイトヘルス → 情報 → サーバー」の PHP のバージョン
サーバー会社の管理画面	PHP のバージョンの設定（ドメインごと）と、サーバー会社のお知らせ

8.1 以前を選んでいるサイトは、サーバー会社が更新しても直りません。管理画面で版を上げます（WordPress やプラグインが新しい版で動くかを、管理されている方と確かめてから）。

3. 社内のサーバー・パソコンで確かめる

どれも**読むだけ**で、何も変更しません。結果をそのまま Incerto にお送りいただいても構いません。
まとめて確かめる場合は、別にお渡しする `php-check.sh`（Linux・Mac）／ `php-check.ps1`（Windows）をお使いください。

Linux・Mac（ターミナル）

① PHP の版

```
php -v
```

② OS の部品として入った PHP（Ubuntu・Debian の場合 ／ RHEL 系の場合）

```
dpkg -l | grep -E '^ii +php[0-9.]*-(cli|fpm|common) '
```

```
rpm -qa | grep -E '^php[0-9]*(-cli|-fpm|-common)?-[0-9]'
```

③ Apache に組み込んで動かしているか ／ PHP-FPM で動かしているか

```
apachectl -M 2>/dev/null | grep -i php
```

```
ps aux | grep 'php-fpm: master' | grep -v grep
```

④ 開発元が挙げる緩和の設定の今の値

```
php -i | grep session.upload_progress.enabled
```

Windows（PowerShell）

① PATH の通った PHP と版

```
Get-Command php.exe -All -ErrorAction SilentlyContinue |
  ForEach-Object { '{0}  {1}' -f $_.Source, $_.Version }
```

② よく使われる場所の PHP と版（XAMPP・C:\php・Laragon・WAMP）

```
$p = @('C:\xampp\php\php.exe', 'C:\php\php.exe',
       'C:\laragon\bin\php\*\php.exe', 'C:\wamp64\bin\php\*\php.exe')
Get-ChildItem $p -ErrorAction SilentlyContinue |
  ForEach-Object { '{0}  {1}' -f $_.FullName, $_.VersionInfo.ProductVersion }
```

③ PHP や Apache を動かしているサービス

```
Get-CimInstance Win32_Service |
  Where-Object { $_.PathName -match 'php|httpd|apache' } |
  Format-Table Name, State, PathName -AutoSize
```

④ IIS で PHP を使っているか（IIS がある場合）

```
& "$env:windir\system32\inetsrv\appcmd.exe" list config -section:system.webServer/fastCgi
```

4. 結果の読み方

結果	意味	すること
8.2.35 ／ 8.3.36 ／ 8.4.27 ／ 8.5.12 より前	対象の版	修正版へ更新する
上の版以降	修正済み	対応済み
8.1 以前（7.x・5.x を含む）	サポートが終わった版。修正版は出ない	サポート中の版へ上げる
② に php のパッケージが出た	OS が配っている PHP。OS の提供元が、版の番号を変えずに直しを入れる	番号では判断せず、OS の更新（apt ／ dnf）と提供元のセキュリティ情報を確かめる
③ に php_module が出た（Linux）／ Apache のサービスと PHP がある（Windows・XAMPP）	Apache に組み込んで動かしている（mod_php）。開発元の告知では影響がいちばん大きい形	更新を急ぐ
④ が On	開発元が挙げる緩和の設定が、まだ有効	更新までのつなぎとして Off にするのが緩和の1つ（更新の代わりにはならない）。変える前に管理者と相談し、Web の処理を再起動する

5. 更新のしかた

動かし方	更新のしかた
レンタルサーバー	サーバー会社が更新する。8.1 以前を選んでいるサイトは、管理画面で版を上げる
Ubuntu・Debian の部品	OS を更新する（`apt`。提供元が直しを出してから）
RHEL・Rocky・Alma の部品	OS を更新する（`dnf`。提供元が直しを出してから）
公式の PHP のコンテナ	新しいイメージを取り直して作り直す
Windows（XAMPP・手で入れた PHP）	https://windows.php.net/download/ から修正版を入れ直す

すぐに更新できない場合
修正が済むまでの間、サイトや仕組みを一時的に止めることも、有効な対策の一つとされています（首相・国家サイバー統括室の呼びかけ）。使っていないサイトや仕組みは、この機会に止めることもご検討ください。